

Botnets & Amplification Attacks

The botnet assembly

Vulnerable army: default-creds IoT, unpatched web shells, phone apps

Loader: first-stage bins infects → downloads second-stage agent

C2: commands via IRC or (modern) HTTP/HTTPS/DNS/blockchain-based beacons

Panic button: the bot waits; when told (frequently via a central 'order board'), floods

Mirai's lesson: 600k cameras/watchdogs pounded the internet's DNS, took Dyn down (2016)

Properties that make them hard

Distributed: 1M+ IPs → near-saturation of core routers

Rotating: many bot IPs change constantly (NAT/AS/potato)

Fast flux / DGA C2 makes takedown slow

Volume comes from *aggregating* many modest hosts – not one giant attacker

Amplification elements

Open resolvers (DNS), NTP monlist, SSDP (UPnP), memcached (2018, record 1.35 Tbps), CLDAP, SNMP. All answered by **anyone** with spoofable source – hence reflectors.

```
# Why it works:          tiny query -> giant response, victim spoofed
attacker ----tiny----> reflector -----huge-----> victim(IP spoofed)
```

Defense roll-up

Ingress filtering (BCP38/BCP84) at ISPs kills spoofing upstream – demand it

open resolver closure – an org hygiene item

DDoS-scrub center + CDN

Keep YOUR appliances patched (don't be the botnet's bot)

Monitor egress: if your network hosts resolve 100k memcached req/s → reflect too

Response posture

For a 50K-employee org: CDN + ISP DDoS protection + DNS provider DDoS shielding + public 'status' page. For a home user: your ISP handles most; keep firmware updated.

Botnet resilience comes from the same sources you defend: bad passwords, unpatched devices, open services. Patch+segment+monitor = you neither host nor reflect an attack.

[← DoS & DDoS: Volumetric, Prot...](#)

[IDS/IPS & Firewall Evasion →](#)